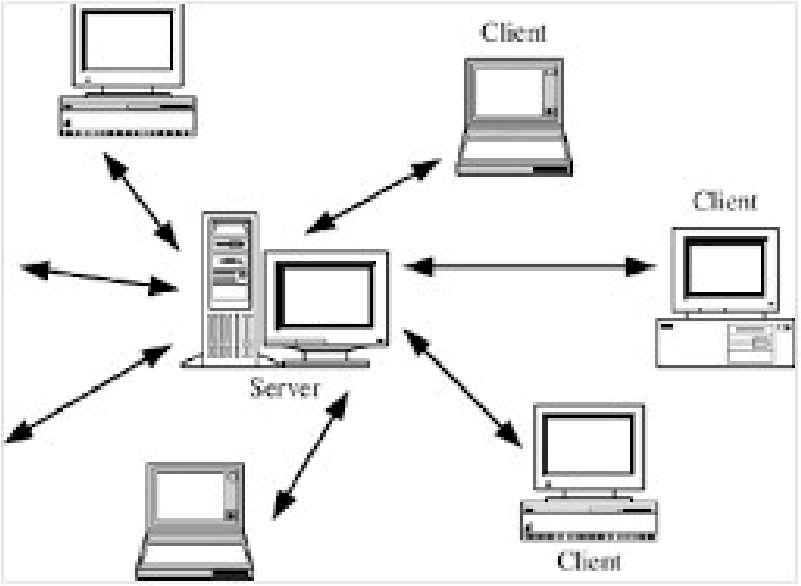


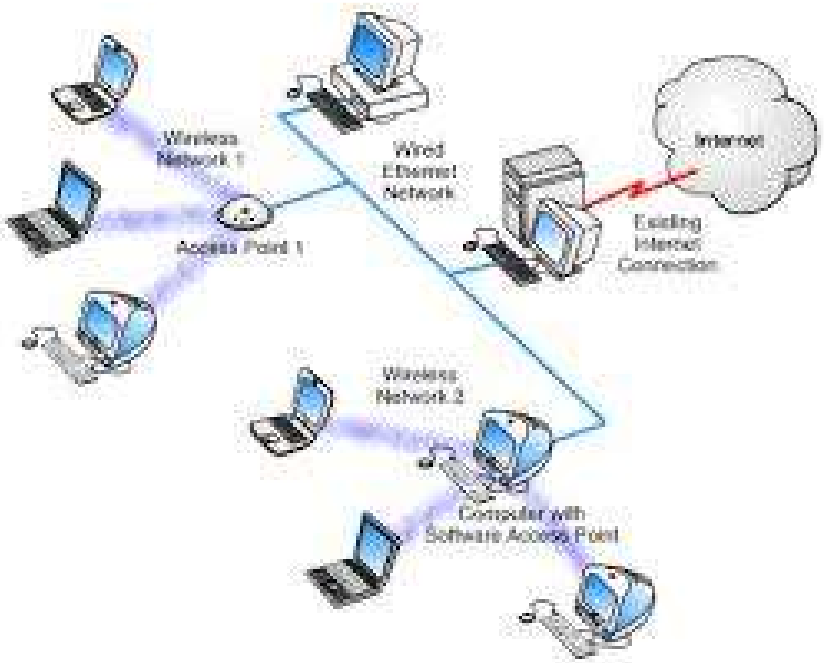
Server: & Client:

Server:

- It is a computer which stores data and sends it when asked for.

Client:

- The computer or device which requests data from other computer or server.



Data Packets:

- All data travels in the Internet in small chunks called Data Packets.
- This is done to make internet communication more efficient.

Types of Servers :

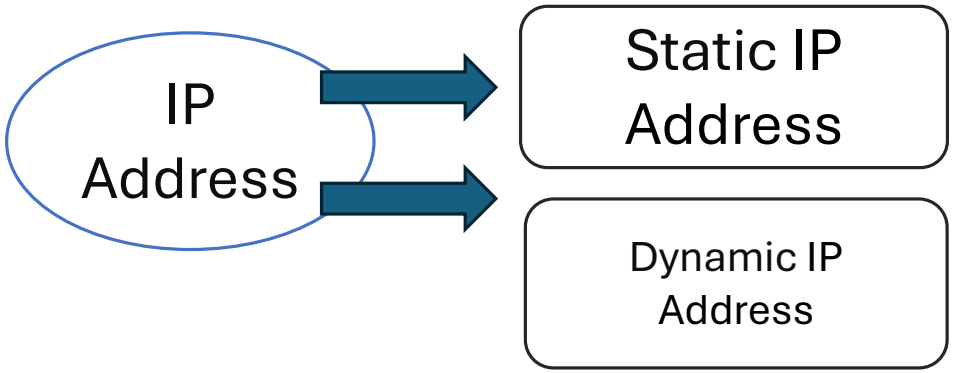
- 1. Proxy server
- 2. Mail server
- 3. Web server
- 4. Application server
- 5. Real-time Communication Server
- 6. FTP Server (File Transfer Protocol)
- 7. List Server
- 8. Telnet Server
- 9. Open Source Server
- 10. Virtual Server.

IP Address: (Internet Protocol)

It is a numerical label assigned to each device connected to a computer network that uses internet or communication.

IP Addresses has two Principal functions:

- Host or network interface identification
- Location Addressing



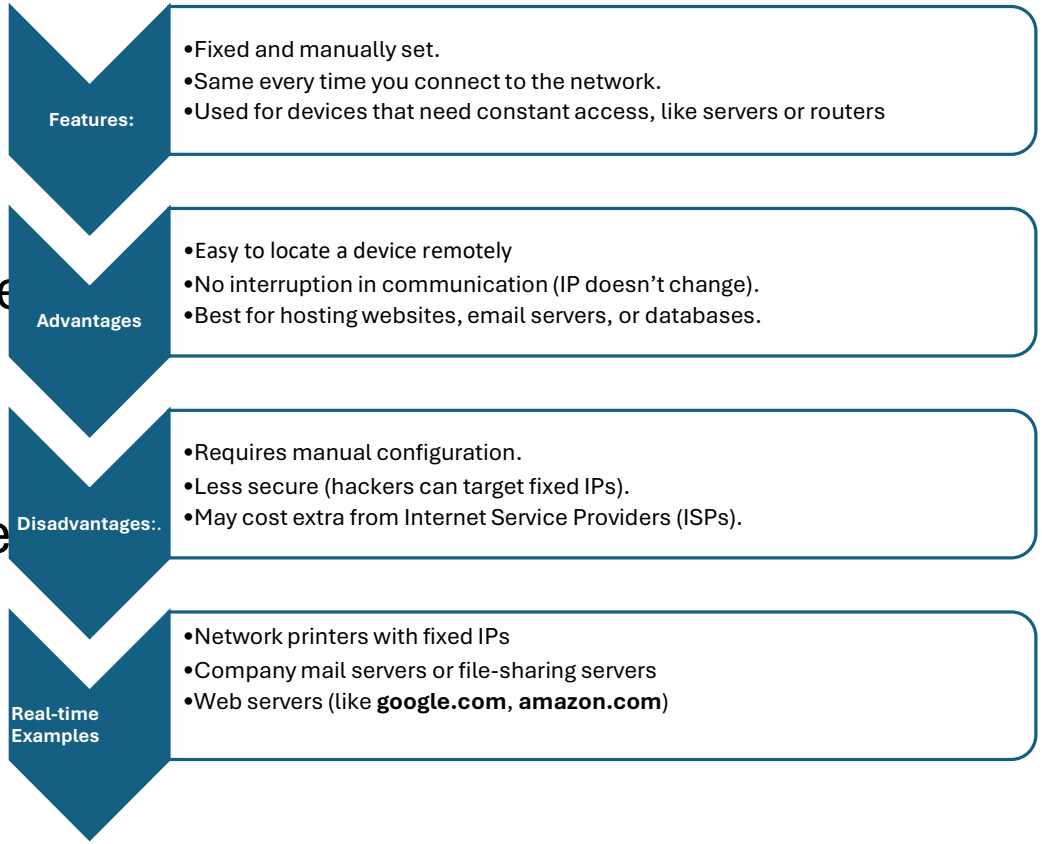
Static IP Address

Definition:

- A **Static IP Address** is an IP that **does not change**. It is **manually assigned** to a device by the network administrator.

How to Explain:

- “It’s like your permanent home address — it always stays the same so anyone can contact you easily.”

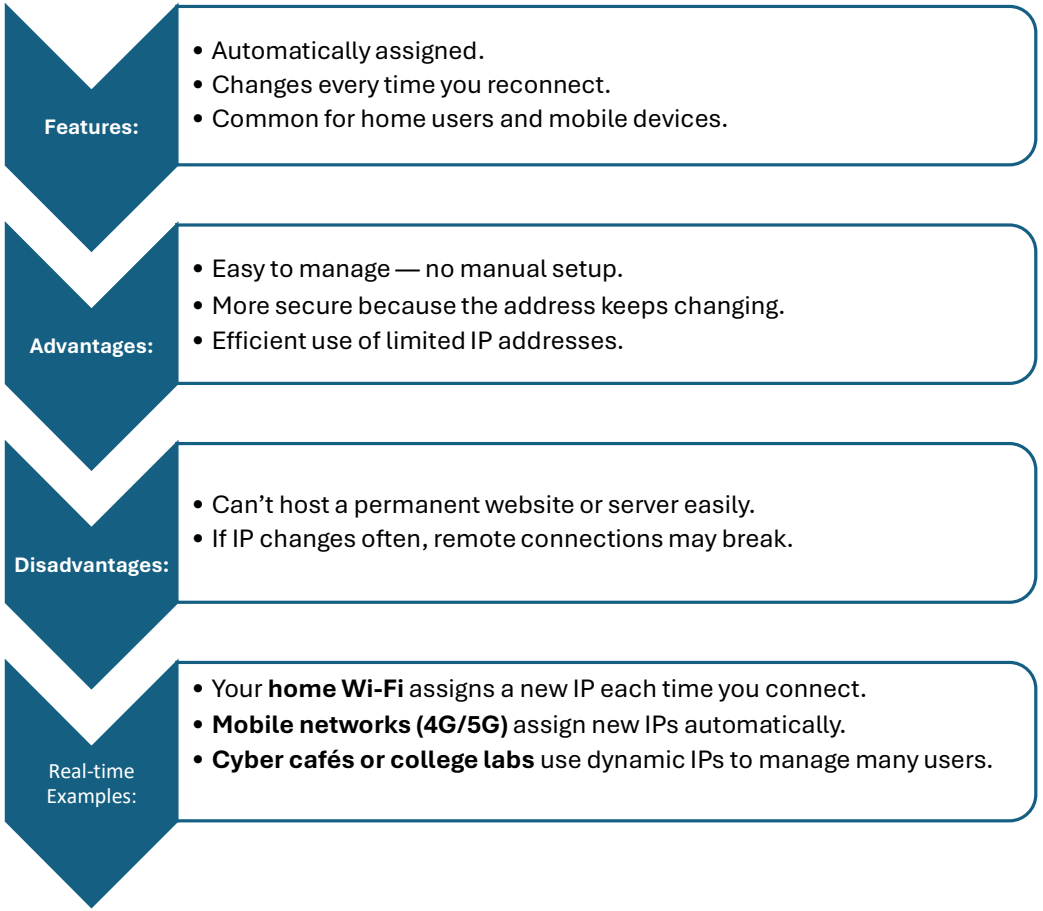


Dynamic IP Address

- A **Dynamic IP Address** is an IP that **changes automatically** each time a device connects to the network.
  It is **assigned by a DHCP (Dynamic Host Configuration Protocol)** server.

How to Explain:

- "It's like staying in a hotel — every time you visit, you might get a different room number."



Domain Name:

- It is the human understandable name assigned to an IP Address
- Example: www.facebook.com, www.google.com

- Parts of a Domain Name:
- Top level domain
- Authoritative domain
- Subdomain
- Root name
- www.maps.google.com.

Why should we learn about subdomains

- To find out which website of the company has more vulnerabilitites
- To find out the website which can be easily accessible
- Why should we know about the parts of a domain name?
- To find out which kind of website it is
- To know which country website it is
- Example
- .org -Organization websites
- .in-India
- .gov-Government websites
- .ac.in -Indian academic institutional websites
- .edu.in -Indian educational institution websites

What are network protocols?

- **Network protocols** are a set of rules, conventions, and data structures that dictate how devices exchange data across networks. In other words, network protocols can be equated to languages that two devices must understand for seamless communication of information, regardless of their infrastructure and design disparities

Types of network protocols

- Application layer network protocols
- Presentation layer network protocols
- Session layer network protocols
- Transport layer network protocols
- Network layer protocols
- Data link layer network protocols

1. DHCP: Dynamic Host Configuration Protocol

- DHCP is a communication protocol that enables network administrators to automate the assignment of IP addresses in a network. In an IP network, every device connecting to the internet requires a unique IP. DHCP lets network admins distribute IP addresses from a central point and automatically send a new IP address when a device is plugged in from a different place in the network. DHCP works on a client-server model.
- **Advantages of using DHCP**
- Centralized management of IP addresses.
- Seamless addition of new clients into a network.
- Reuse of IP addresses, reducing the total number of IP addresses required.
- **Disadvantages of using DHCP**
- Tracking internet activity becomes tedious, as the same device can have multiple IP addresses over a period of time.
- Computers with DHCP cannot be used as servers, as their IPs change over time.

2. DNS: Domain Name System protocol

- The DNS protocol helps in translating or mapping host names to IP addresses. DNS works on a client-server model, and uses a distributed database over a hierarchy of name servers.
- Hosts are identified based on their IP addresses, but memorizing an IP address is difficult due to its complexity. IPs are also dynamic, making it all the more necessary to map domain names to IP addresses. DNS helps resolve this issue by converting the domain names of websites into numerical IP addresses.
- **Advantages**
- DNS facilitates internet access.
- Eliminates the need to memorize IP addresses.
- **Disadvantages**
- DNS queries don't carry information pertaining to the client who initiated it. This is because the DNS server only sees the IP from where the query came from, making the server susceptible to manipulation from hackers.
- DNS root servers, if compromised, could enable hackers to redirect to other pages for phishing data.

3. FTP: File Transfer Protocol

- File Transfer Protocol enables file sharing between hosts, both local and remote, and runs on top of TCP. For file transfer, FTP creates two TCP connections: control and data connection. The control connection is used to transfer control information like passwords, commands to retrieve and store files, etc., and the data connection is used to transfer the actual file. Both of these connections run in parallel during the entire file transfer process.
- **Advantages**
- Enables sharing large files and multiple directories at the same time.
- Lets you resume file sharing if it was interrupted.
- Lets you recover lost data, and schedule a file transfer.
- **Disadvantages**
- FTP lacks security. Data, usernames, and passwords are transferred in plain text, making them vulnerable to malicious actors.
- FTP lacks encryption capabilities, making it non-compliant with industry standards.

4. HTTP: Hyper Text Transfer Protocol

- HTTP is an application layer protocol used for distributed, collaborative, and hypermedia information systems. It works on a client-server model, where the web browser acts as the client. Data such as text, images, and other multimedia files are shared over the World Wide Web using HTTP. As a request and response type protocol, the client sends a request to the server, which is then processed by the server before sending a response back to the client.
- HTTP is a stateless protocol, meaning the client and server are only aware of each other while the connection between them is intact. After that, both the client and server forget about each other's existence. Due to this phenomenon, the client and server can't both retain information between requests.
- **Advantages**
- Memory usage and CPU usage are low because of lesser concurrent connections.
- Errors can be reported without closing connections.
- Owing to lesser TCP connections, network congestion is reduced.
- **Disadvantages**
- HTTP lacks encryption capabilities, making it less secure.
- HTTP requires more power to establish communication and transfer data.

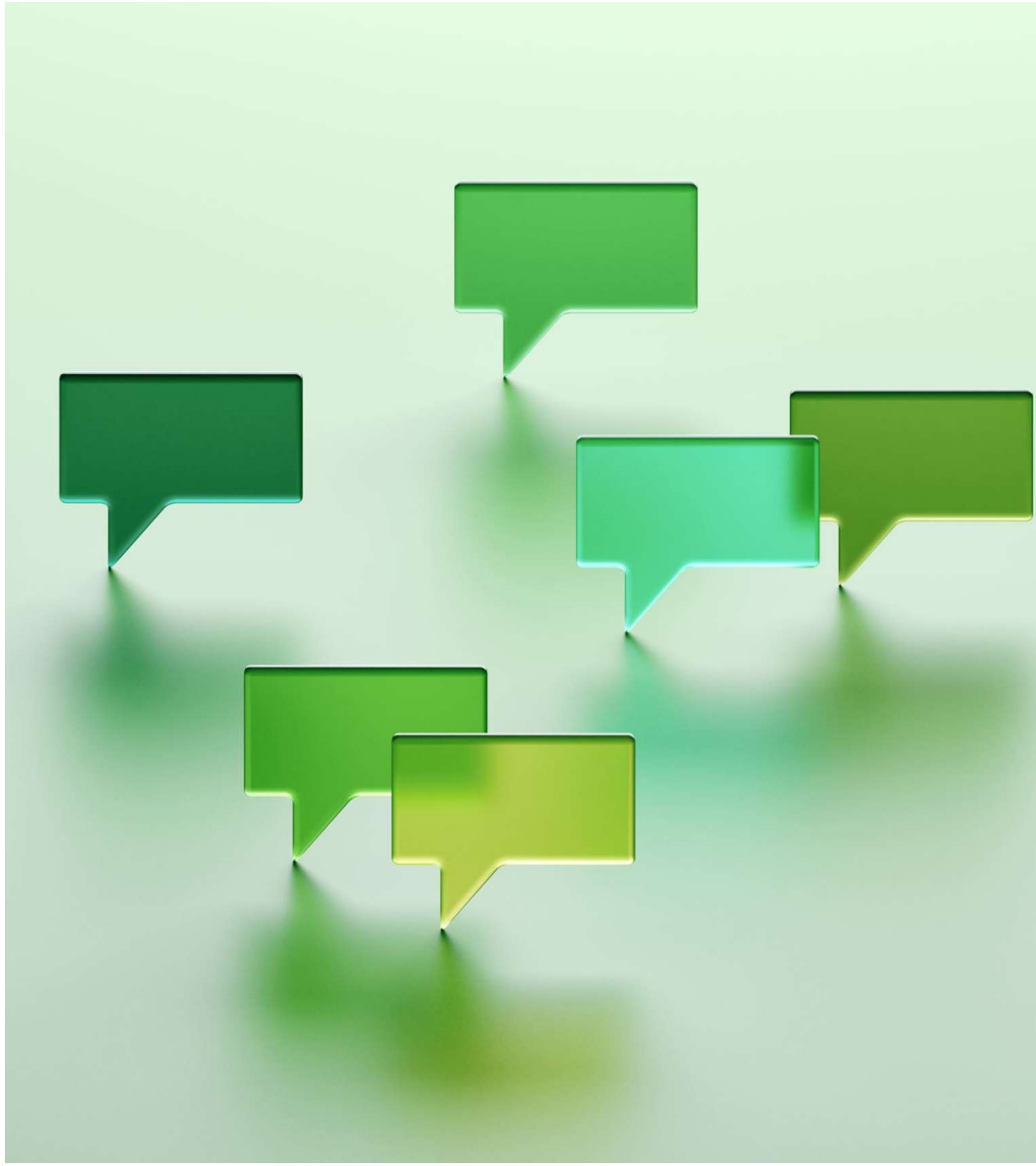
5. IMAP and IMAP4: Internet Message Access Protocol (version 4)



- IMAP is an email protocol that lets end users access and manipulate messages stored on a mail server from their email client as if they were present locally on their remote device. IMAP follows a client-server model, and lets multiple clients access messages on a common mail server concurrently. IMAP includes operations for creating, deleting, and renaming mailboxes; checking for new messages; permanently removing messages; setting and removing flags; and much more. The current version of IMAP is version 4 revision 1.
- **Advantages**
- As the emails are stored on the mail server, local storage utilization is minimal.
- In case of accidental deletion of emails or data, it is always possible to retrieve them as they are stored on the mail server.
- **Disadvantages**
- Emails won't work without an active internet connection.
- High utilization of emails by end users requires more mailbox storage, thereby augmenting costs.

6. POP and POP3: Post Office Protocol (version 3)

- The Post Office Protocol is also an email protocol. Using this protocol, the end user can download emails from the mail server to their own email client. Once the emails are downloaded locally, they can be read without an internet connection. Also, once the emails are moved locally, they get deleted from the mail server, freeing up space. POP3 is not designed to perform extensive manipulations with the messages on the mail server, unlike IMAP4. POP3 is the latest version of the Post Office Protocol.
- **Advantages**
- Read emails on local devices without internet connection.
- The mail server need not have high storage capacity, as the emails get deleted when they're moved locally.
- **Disadvantages**
- If the local device on which the emails were downloaded crashes or gets stolen, the emails are lost.



7. SMTP: Simple Mail Transfer Protocol

- SMTP is a protocol designed to transfer electronic mail reliably and efficiently. SMTP is a push protocol and is used to send the email, whereas POP and IMAP are used to retrieve emails on the end user's side. SMTP transfers emails between systems, and notifies on incoming emails. Using SMTP, a client can transfer an email to another client on the same network or another network through a relay or gateway access available to both networks.
- **Advantages**
- Ease of installation.
- Connects to any system without any restriction.
- It doesn't need any development from your side.
- **Disadvantages**
- Back and forth conversations between servers can delay sending a message, and also increases the chance of the message not being delivered.
- Certain firewalls can block the ports used with SMTP.

8. Telnet: Terminal emulation protocol

- Telnet is an application layer protocol that enables a user to communicate with a remote device. A Telnet client is installed on the user's machine, which accesses the command line interface of another remote machine that runs a Telnet server program.
- Telnet is mostly used by network administrators to access and manage remote devices. To access a remote device, a network admin needs to enter the IP or host name of the remote device, after which they will be presented with a virtual terminal that can interact with the host.
- **Advantages**
- Compatible with multiple operating systems.
- Saves a lot of time due to its swift connectivity with remote devices.
- **Disadvantages**
- Telnet lacks encryption capabilities and sends across critical information in clear text, making it easier for malicious actors.
- Expensive due to slow typing speeds.



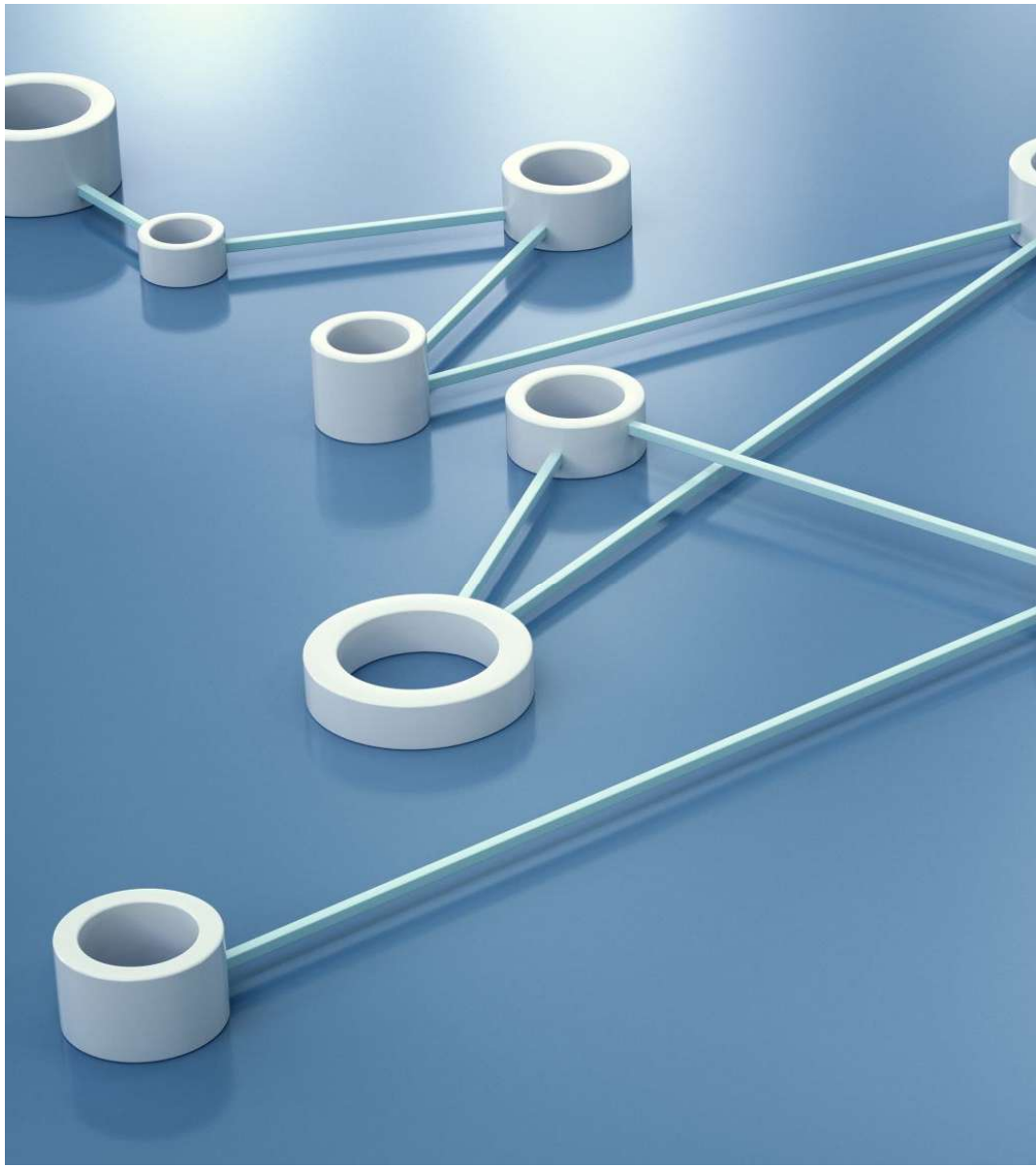
9. SNMP: Simple Network Management Protocol

- SNMP is an application layer protocol used to manage nodes, like servers, workstations, routers, switches, etc., on an IP network. SNMP enables network admins to monitor network performance, identify network glitches, and troubleshoot them. SNMP protocol is comprised of three components: a managed device, an SNMP agent, and an SNMP manager.
- The SNMP agent resides on the managed device. The agent is a software module that has local knowledge of management information, and translates that information into a form compatible with the SNMP manager. The SNMP manager presents the data obtained from the SNMP agent, helping network admins manage nodes effectively.
- Currently, there are three versions of SNMP: SNMP v1, SNMP v2, and SNMP v3. Both versions 1 and 2 have many features in common, but SNMP v2 offers enhancements such as additional protocol operations. SNMP version 3 (SNMP v3) adds security and remote configuration capabilities to the previous versions.



Presentation layer network protocols-LPP: Lightweight Presentation Protocol

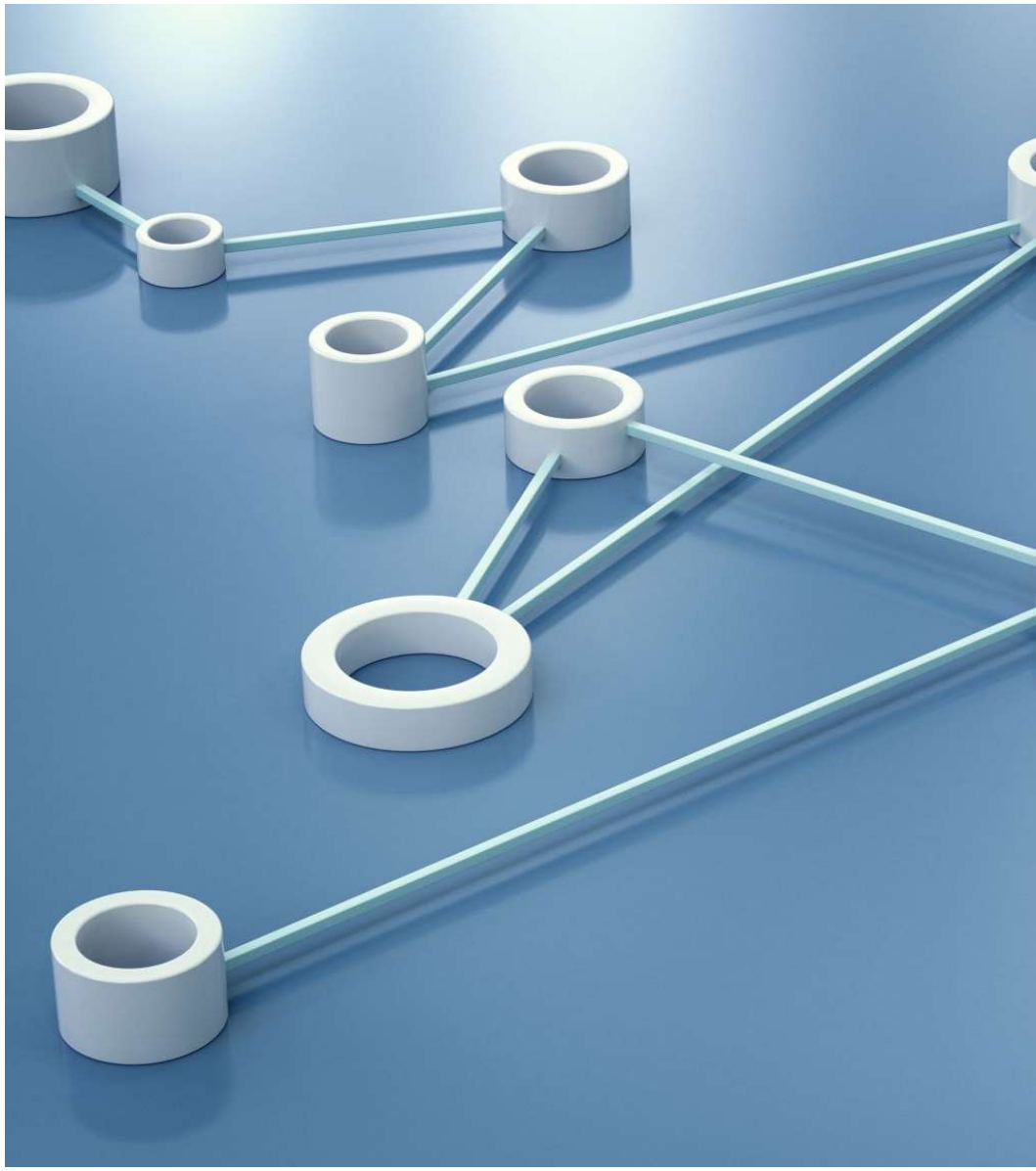
- The Lightweight Presentation Protocol helps provide streamlined support for OSI application services in networks running on TCP/IP protocols for some constrained environments. LPP is designed for a particular class of OSI applications, namely those entities whose application context contains only an Association Control Service Element (ACSE) and a Remote Operations Service Element (ROSE). LPP is not applicable to entities whose application context is more extensive, i.e., contains a Reliable Transfer Service Element.



- Session layer network protocols-RPC: Remote Procedure Call protocol

- RPC is a protocol for requesting a service from a program in a remote computer through a network, and can be used without having to understand the underlying network technologies. RPC uses TCP or UDP for carrying the messages between communicating programs. RPC also works on client-server model. The requesting program is the client, and the service providing program is the server.
- **Advantages**
- RPC omits many protocol layers to improve performance.
- With RPC, code rewriting or redeveloping efforts are minimized.
- **Disadvantages**
- Not yet proven to work effectively over wide-area networks.
- Apart from TCP/IP, RPC does not support other transport protocols.

Transport layer network protocols-TCP: Transmission Control Protocol



- TCP is a transport layer protocol that provides a reliable stream delivery and virtual connection service to applications through the use of sequenced acknowledgement. TCP is a connection-oriented protocol, as it requires a connection to be established between applications before data transfer. Through flow control and acknowledgement of data, TCP provides extensive error checking. TCP ensures sequencing of data, meaning the data packets arrive in order at the receiving end. Retransmission of lost data packets is also feasible with TCP.
- **Advantages**
- TCP ensures three things: data reaches the destination, reaches it on time, and reaches it without duplication.
- TCP automatically breaks data into packets before transmission.
- **Disadvantages**
- TCP cannot be used for broadcast and multicast connections.

2. UDP: User Datagram Protocol

- UDP is a connection-less transport layer protocol that provides a simple but unreliable message service. Unlike TCP, UDP adds no reliability, flow control, or error recovery functions. UDP is useful in situations where the reliability mechanisms of TCP are not necessary. Retransmission of lost data packets isn't possible with UDP.
- **Advantages**
- Broadcast and multicast connections are possible with UDP.
- UDP is faster than TCP.
- **Disadvantages**
- In UDP, it's possible that a packet may not be delivered, be delivered twice, or not be delivered at all.
- Manual disintegration of data packets is needed.





Network layer protocols-IP: Internet Protocol (IPv4)

- IPv4 is a network layer protocol that contains addressing and control information, which helps packets be routed in a network. IP works in tandem with TCP to deliver data packets across the network. Under IP, each host is assigned a 32-bit address comprised of two major parts: the network number and host number. The network number identifies a network and is assigned by the internet, while the host number identifies a host on the network and is assigned by a network admin. The IP is only responsible for delivering the packets, and TCP helps puts them back in the right order.
- **Advantages**
- IPv4 encrypts data to ensure privacy and security.
- With IP, routing data becomes more scalable and economical.
- **Disadvantages**
- IPv4 is labor intensive, complex, and prone to errors.

2. IPv6: Internet Protocol version 6

- IPv6 is the latest version of the Internet Protocol, a network layer protocol that possesses addressing and control information for enabling packets to be routed in the network. IPv6 was created to deal with IPv4 exhaustion. It increases the IP address size from 32 bits to 128 bits to support more levels of addressing.
- **Advantages**
- More efficient routing and packet processing compared to IPv4.
- Better security compared to IPv4.
- **Disadvantages**
- IPv6 is not compatible with machines that run on IPv4.
- Challenge in upgrading the devices to IPv6.



3. ICMP: Internet Control Message Protocol

- ICMP is a network layer supporting protocol used by network devices to send error messages and operational information. ICMP messages delivered in IP packets are used for out-of-band messages related to network operation or misoperation. ICMP is used to announce network errors, congestion, and timeouts, as well assist in troubleshooting.
- **Advantages**
- ICMP is used to diagnose network issues.
- **Disadvantages**
- Sending a lot of ICMP messages increases network traffic.
- End users are affected if malicious users send many ICMP destination unreachable packets.

- Data link layer network protocols- ARP: Address Resolution Protocol

- The Address Resolution Protocol helps map IP addresses to physical machine addresses (or a MAC address for Ethernet) recognized in the local network. A table called an ARP cache is used to maintain a correlation between each IP address and its corresponding MAC address. ARP offers the rules to make these correlations, and helps convert addresses in both directions.
- **Advantages**
- MAC addresses need not be known or memorized, as the ARP cache contains all the MAC addresses and maps them automatically with IPs.
- **Disadvantages**
- ARP is susceptible to security attacks called ARP spoofing attacks.
- When using ARP, sometimes a hacker might be able to stop the traffic altogether. This is also known as ARP denial-of-services.

SLIP: Serial Line IP

- SLIP is used for point-to-point serial connections using TCP/IP. SLIP is used on dedicated serial links, and sometimes for dial-up purposes. SLIP is useful for allowing mixes of hosts and routers to communicate with one another; for example, host-host, host-router, and router-router are all common SLIP network configurations. SLIP is merely a packet framing protocol: It defines a sequence of characters that frame IP packets on a serial line. It does not provide addressing, packet type identification, error detection or correction, or compression mechanisms.
- **Advantages**
- Since it has a small overhead, it is suitable for usage in microcontrollers.
- It reuses existing dial-up connections and telephone lines.
- It's easy to deploy since it's based on the Internet Protocol.
- **DIsadvantages**
- SLIP doesn't support automatic setup of network connections in multiple OSI layers at the same time.
- SLIP does not support synchronous connections, such as a connection created through the internet from a modem to an internet service provider (ISP).



Firewalls

- A **firewall** is a **network security device or software** that **monitors and controls incoming and outgoing network traffic** based on predefined **security rules**.
  Its main goal is to **protect your system or network from unauthorized access, viruses, and hackers**.

- It acts like a **security guard** at the entrance of your network — allowing or blocking traffic based on rules.

1. Packet Filtering Firewall

- **Description:**
  It checks IP addresses, ports, and protocols of every data packet before allowing it through.
- **Real-Time Example:**
- A company's **router firewall** is configured to block all **incoming traffic on port 23 (Telnet)** because Telnet is insecure.
- Only **port 80 (HTTP)** and **port 443 (HTTPS)** are allowed for web access.
  Example device: *Cisco Access Control Lists (ACLs)* used in routers.
- **Summary:**
- Like checking the "from" and "to" address on a letter before delivering it.

2. Stateful Inspection Firewall

- **Description:**
  It doesn't just look at individual packets — it keeps track of active connections (session state) to allow only legitimate ongoing traffic.
- **Real-Time Example:**
- When you connect to your **online banking website**, the firewall allows responses from that same session only.
- If a hacker sends random packets pretending to be your bank, the firewall rejects them because they don't match an existing session.
  Example device: *Checkpoint Firewall, Cisco ASA*.
- **Summary:**
- Like allowing a person back into a building only if they already checked in at the reception earlier.

3. Proxy Firewall (Application Layer Firewall)

- **Description:**
  Acts as a middleman (proxy) between users and external websites — inspects content at the **Application Layer (Layer 7)**.
- **Real-Time Example:**
- In a **corporate office**, all employee web traffic goes through a **web proxy** (e.g., *Squid Proxy, Blue Coat ProxySG*).
- If an employee tries to open **Facebook**, the proxy checks company policy and **blocks the site**.
- It can also **scan downloaded files for malware** before they reach the user.
- **Summary:**
- Like a security officer checking every message between two people before passing it on.

4. Next-Generation Firewall (NGFW)

Description:
A modern firewall that includes deep packet inspection, intrusion prevention (IPS), malware protection, and **application-level filtering** — all in one.

- **Real-Time Example:**
- A company uses **Palo Alto Networks**, **Fortinet**, or **Cisco Firepower** to detect and block:
  - Malware downloads
  - Phishing links
  - Application misuse (e.g., someone using VPN or torrenting at work)
- The NGFW automatically updates with **real-time threat intelligence** to stop new cyberattacks.
- 🔸 **Summary:**
- Like a smart security system that recognizes faces, checks IDs, and blocks intruders instantly.

IDS (Intrusion Detection System):

A monitoring system that detects suspicious or malicious activity in a network and **alerts the administrator**.
→ *Think of it as a CCTV camera for your network.*

How It Works:

- Monitors network packets, system logs, and user activity.
- Compares behavior against known attack signatures or unusual patterns.
- Sends alerts when suspicious activity is detected.

🌐 **Real-Time Example 1:**

- A **university network** uses **Snort IDS** or **Suricata** to monitor student network activity.
  When the system detects **multiple failed login attempts** or **port scans**, it sends an alert to the network admin.

🌐 **Real-Time Example 2:**

- In a **bank's data center**, the IDS detects that a user is trying to access files outside their department.
  The IDS immediately **alerts the cybersecurity team** via email or dashboard.

🧠 **Summary:**

IDS = Detects → Warns the Admin
🛠 Example Tools: *Snort, OSSEC, Suricata, Zeek (Bro).*



IPS (Intrusion Prevention System):

An active protection system that not only detects malicious traffic but also **blocks or prevents it automatically**.
→ *Think of it as a security guard who stops the intruder immediately.*

- **How It Works:**
- Placed **inline** with the network traffic (between router and switch).
- It inspects each packet and **automatically blocks or drops** malicious ones.
- 🌐 **Real-Time Example 1:**
- A **corporate network** uses **Cisco Firepower** or **Palo Alto Networks NGFW** (which include IPS features).
  When a hacker tries a **SQL injection** on the company's website, the IPS detects the attack pattern and **instantly blocks the packet**.
- 🌐 **Real-Time Example 2:**
- An **e-commerce website** has an IPS that detects a **DDoS (Distributed Denial of Service)** attack.
  It automatically blocks traffic from the attacker's IP addresses, keeping the site online and stable.
- 🧠 **Summary:**
- IPS = Detects → Blocks automatically
  🛠️ Example Tools: *Cisco Firepower, Palo Alto Networks, Fortinet FortiGate, Snort IPS.*

Common Network Attacks

- **1. Denial of Service (DoS) / Distributed Denial of Service (DDoS) Attack**
- 🧠 **What it is:**
  Attackers flood a server or network with excessive traffic, making it **unavailable** to real users.
- 🌐 **Real-Time Example:**
- A shopping website like **Amazon** or **Flipkart** receives millions of fake requests from bots, causing the site to **crash during a sale**.
- DDoS tools: LOIC (Low Orbit Ion Cannon), HOIC.
- 💡 **Prevention:**
  Use firewalls, **load balancers**, and **anti-DDoS services** (like Cloudflare, AWS Shield).

2. Phishing Attack

- 🧠 **What it is:**
  Attackers send fake emails or messages pretending to be from trusted sources (banks, companies) to steal **passwords or credit card info**.
- 🌐 **Real-Time Example:**
- You receive an email saying “Your SBI account will be blocked — click here to verify.”
- The link leads to a **fake login page**, stealing your credentials.
- 💡 **Prevention:**
  Check sender address, use spam filters, enable 2FA.

3. Man-in-the-Middle (MITM) Attack

- 🧠 **What it is:**
  An attacker secretly intercepts and alters communication between two parties without their knowledge.
- 🌐 **Real-Time Example:**
- You connect to **public Wi-Fi** at an airport.
- A hacker captures your data (passwords, messages) between your device and the server.
- 💡 **Prevention:**
  Use HTTPS websites, **VPNs**, and avoid public Wi-Fi for sensitive tasks.

IP Spoofing

- 🧠 **What it is:**
  The attacker sends data packets with a fake source IP address to trick the system into thinking it's from a trusted source.
- 🌐 **Real-Time Example:**
- A hacker pretends to be an **internal company server** by using its IP address to bypass firewall rules.
- 💡 **Prevention:**
  Use packet filtering firewalls and **authentication protocols**.

6. ARP Spoofing (ARP Poisoning)

- 🧠 **What it is:**
  Attackers send fake ARP messages to link their MAC address with another device's IP address — redirecting traffic to themselves.
- 🌐 **Real-Time Example:**
- Inside an organization, a hacker uses ARP spoofing to intercept data between employees and the company gateway.
- 💡 **Prevention:**
  Use static ARP entries, **packet sniffers**, and **encryption**

7. DNS Spoofing (DNS Poisoning)

7. DNS Spoofing (DNS Poisoning)

🧠 **What it is:**
Attackers alter DNS records to redirect users to **malicious websites** instead of legitimate ones.

🌐 **Real-Time Example:**

- You try to visit **www.gmail.com**, but the attacker redirects you to a **fake Gmail login page** to steal your password.

💡 **Prevention:**
Use **DNSSEC** and **trusted DNS servers**.

9. Brute Force Attack

- 🧠 **What it is:**
  Attackers try all possible combinations of passwords until they find the correct one.
- 🌐 **Real-Time Example:**
- An attacker uses a tool like **Hydra** or **John the Ripper** to guess admin passwords on a web server.
- 💡 **Prevention:**
  Use strong passwords, **account lockouts**, and **multi-factor authentication**.

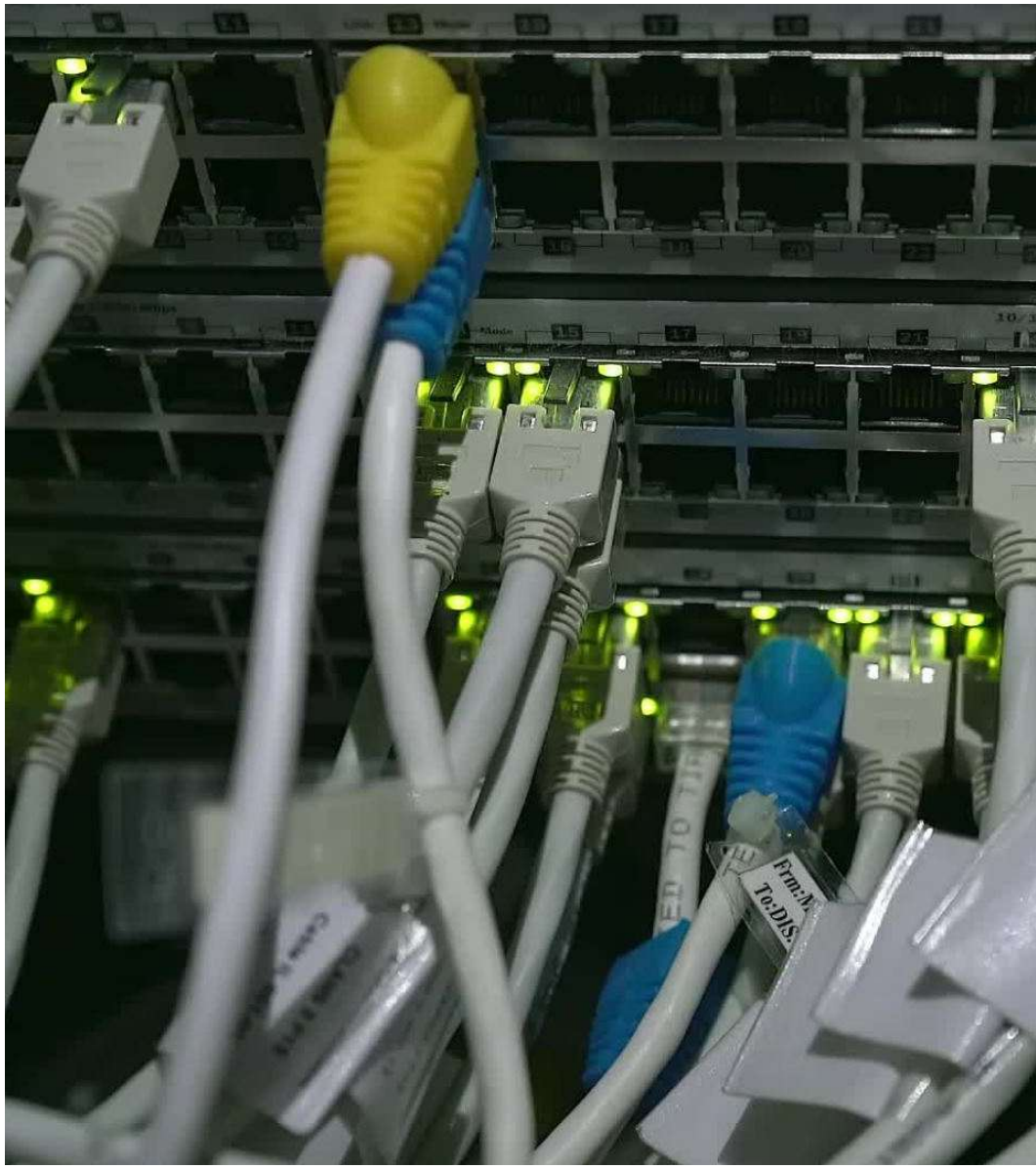


10. Malware Attack



Wireshark

- **Wireshark** is a **network protocol analyzer** — a tool that allows you to **capture and inspect the data packets** that travel through a network in real time.
- Think of it like a **CCTV camera for your network**:
  it watches every packet going in or out of your computer and lets you examine exactly what's inside — headers, protocols, source & destination, etc.



Why Do We Use Wireshark?

- We use Wireshark to **analyze, troubleshoot, and secure networks**.
  Here's what it helps with, step by step:

Purpose	Description	Real-Time Example
1. Network Troubleshooting	Identify where communication is failing between devices or servers.	A user says "Internet is slow" → Wireshark shows lots of **TCP retransmissions** → indicates packet loss or cable issue.
2. Protocol Analysis	See how protocols (HTTP, DNS, TCP, UDP, etc.) actually work.	You capture a **DNS request** and response to show how a domain name resolves to an IP.
3. Security Analysis	Detect malicious traffic, attacks, or suspicious packets.	If malware is exfiltrating data, Wireshark might show **suspicious IPs** or **unusual ports**.
4. Learning / Education	Helps students understand how data travels in a network.	You can visualize a **3-way TCP handshake** (SYN → SYN/ACK → ACK).
5. Debugging Applications	Developers use it to debug app network requests.	A web app's API call fails → capture packets → check HTTP status code or missing headers.

• What Wireshark Can Capture

Wireshark can capture and display data for these types of traffic:

- **Ethernet frames** (layer 2)
- **IP packets** (layer 3)
- **TCP/UDP segments** (layer 4)
- **Application layer protocols**: HTTP, HTTPS, DNS, FTP, SMTP, SSH, etc

- **How It Works (Simple Flow)**
- **Capture Packets:**
  Wireshark listens to your network interface card (NIC) in "promiscuous mode" (captures all packets that pass through your system).
- **Decode Protocols:**
  Each packet is decoded according to its protocol — e.g., Ethernet → IP → TCP → HTTP.
- **Display in Real Time:**
  It displays packet details in three panes:
  - **Packet List Pane:** overview of captured packets.
  - **Packet Details Pane:** protocol layers and header details.
  - **Packet Bytes Pane:** raw data (hexadecimal view).

Wireshark Tools

- **Capture Filters:** set before capture to limit what's recorded (e.g., `tcp port 80`).
- **Display Filters:** applied after capture to analyze specific traffic (`ip.addr == 8.8.8.8`).
- **Follow TCP Stream:** reconstructs a full conversation between two devices.
- **Export Objects:** save files transferred over protocols like HTTP or FTP.

Feature	Description
Tool Name	Wireshark
Purpose	Network packet capture and analysis
Used By	Network engineers, cybersecurity analysts, students
Helps With	Troubleshooting, security auditing, learning
Real Example	Capture HTTP or DNS packets, find slow network cause
Type of Tool	Packet sniffer & analyzer

What is OS Security?

- **OS Security** means protecting the **operating system** (Windows, Linux, macOS, etc.) from:
- Unauthorized access
- Malware and viruses
- System crashes
- Data theft or corruption
- In simple terms — it ensures that **only the right people** can use the system, and **only in the right way**

Os system

- 2. **Authorization**
- Controls what actions a user can perform after login.
- Managed by **permissions and access control**.
- 🧩 *Example:*
  An "Admin" can install apps, but a "Guest" cannot.

.

- 3. **Encryption**
- Converts readable data into unreadable form to protect it.
- Used for securing data at rest (in storage) or in transit (over network).
- 🧩 *Example:*
  BitLocker in Windows or FileVault in macOS encrypts your entire disk.

Os system

- 4. **Firewalls**
- Blocks or allows network traffic based on security rules.
- Protects the system from unauthorized access.
- 🧩 *Example:*
  Windows Defender Firewall blocking unknown apps from accessing the internet.
-
- 5. **Antivirus and Anti-Malware**
- Detects and removes viruses, trojans, and spyware.
- 🧩 *Example:*
  Windows Defender, Avast, or Kaspersky scanning files for malicious code.

- 6. **Security Updates and Patch Management**
- Regular updates fix known vulnerabilities in the OS.
- 🧩 *Example:*
  Microsoft's "Patch Tuesday" updates fix security bugs in Windows.
-
- 7. **Access Control Lists (ACLs)**
- Define which users or groups can access files, folders, or devices.
- 🧩 *Example:*
  Only a manager group can open salary data folder in a company server.

Os system

- 8. **Auditing and Logging**
- Keeps a record of who did what and when.
- Helps in detecting unauthorized activity.
- 🧩 *Example:*
  Windows Event Viewer logs every login attempt.
-

- 9. **Backup and Recovery**
- Protects data from accidental deletion or corruption.
- 🧩 *Example:*
  Windows "System Restore" or Linux "rsync" backups.

Operating system

Threat	Description	Example
Malware	Software designed to harm or steal data	Viruses, worms, trojans
Phishing	Fake login pages or emails stealing passwords	“Update your account” scam emails
Privilege Escalation	Attacker gains higher access rights	A normal user becomes admin
Denial of Service (DoS)	System overloaded with fake requests	Website becomes unavailable
Zero-Day Attack	Exploits unknown vulnerabilities	Hackers using unpatched OS flaws
Unauthorized Access	Logging into another user’s account	Weak passwords or no 2FA

What is Software Development?

- **Software Development** is the **process of designing, creating, testing, and maintaining** computer programs or applications that perform specific tasks.
- It involves everything from writing code to building user interfaces and ensuring that the software works correctly and securely.



Real-Time Examples

Example 1: Mobile App Development

- You build a **food delivery app** (like Zomato).
- You design the interface, connect to a backend, and deploy it.
- Users can order food and track delivery — that's software development in action.

Example 2: Web Development

- A company wants a **job portal** website.
- You use **React.js** for frontend and **Node.js** or **Django** for backend.
- The site allows job postings, applications, and tracking — built using SDLC.

Example 3: System Software

- Developers build an **Operating System update** (e.g., Windows 11 patch).
- It improves performance and fixes security vulnerabilities.



Phases of Software Development (SDLC – Software Development Life Cycle)

🔢 Phase	⚙️ Description	💡 Example
1. Requirement Analysis	Understand what the user or client needs.	A client wants an e-commerce app like Amazon.
2. Design	Plan the structure, UI, and database of the system.	Create wireframes and database schema.
3. Implementation (Coding)	Write the actual program using a language like Python, Java, or React.	Build the shopping cart, login system, etc.
4. Testing	Check for bugs and verify if it works as expected.	Run functional and security tests.
5. Deployment	Release the software to users.	Host the app on AWS or Play Store.
6. Maintenance	Fix bugs, add updates, and improve performance.	Release a new version with faster checkout.

What is Secure Software Development?

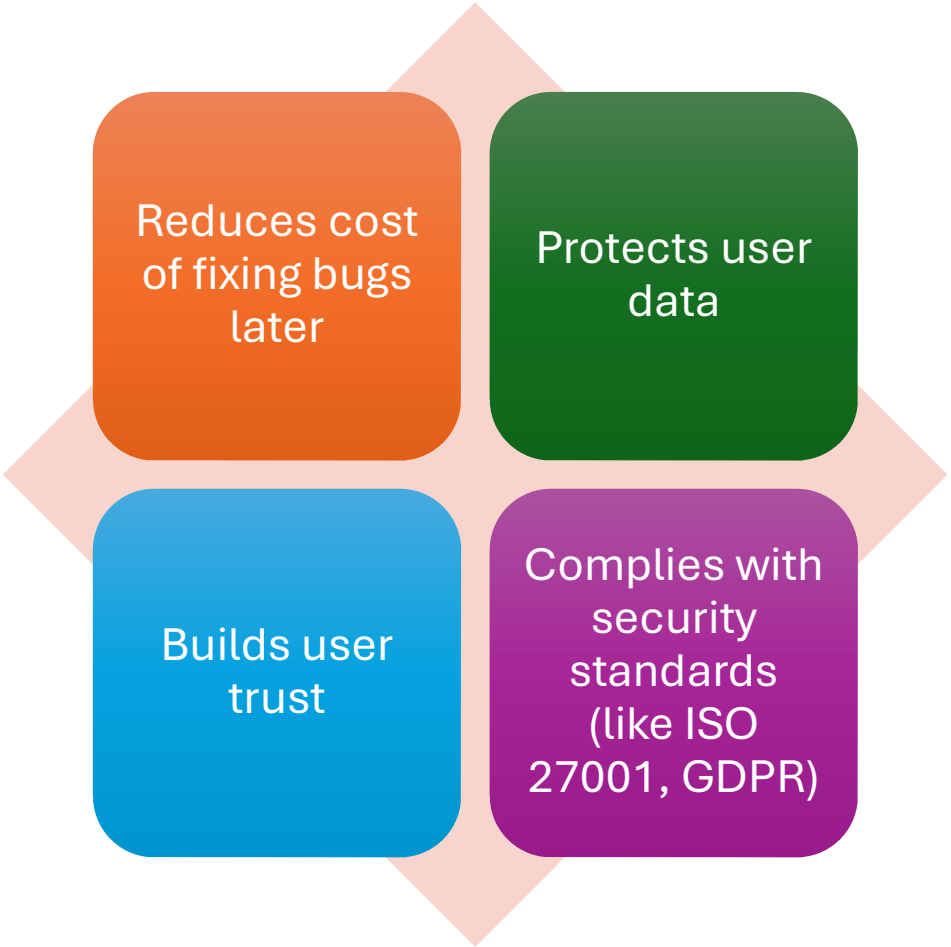
- Secure Software Development means **building software with security in mind from the very beginning** — not just adding it at the end.
- 💡 Goal: To **prevent security vulnerabilities** like hacking, data leaks, or unauthorized access by integrating security into every stage of the development lifecycle.



Phases of Secure SDLC

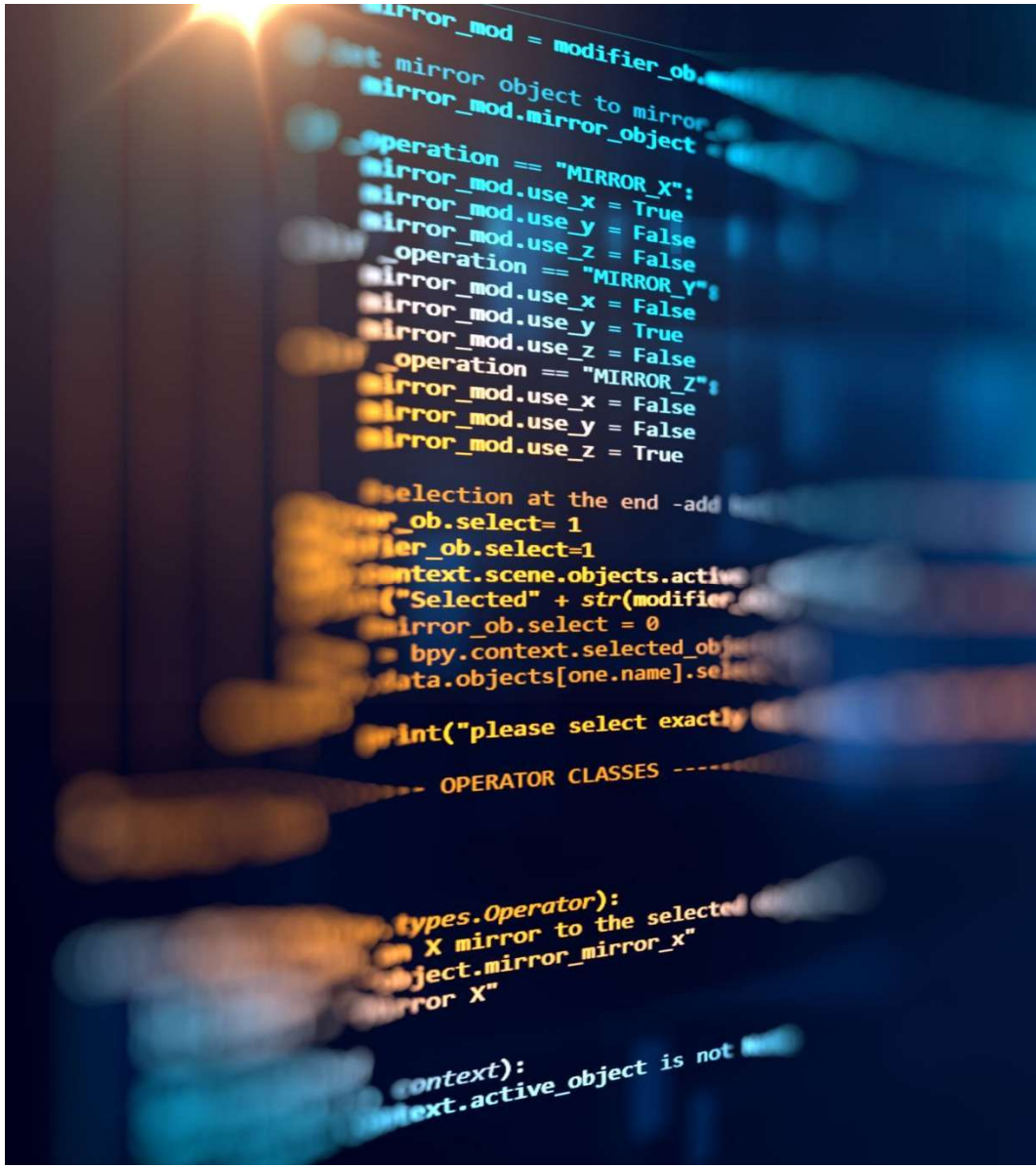
Phase	Main Goal	Security Activities	Example
1. Requirements Analysis	Understand what the software should do	Define security requirements (e.g., password rules, encryption needs)	Login must use 2FA
2. Design	Plan how the software will work	Threat modeling, secure architecture	Designing encrypted data storage
3. Development (Coding)	Write the code	Use secure coding practices, input validation	Avoid SQL Injection, sanitize user input
4. Testing	Check for bugs & security flaws	Perform static and dynamic security testing	Use tools like OWASP ZAP, Burp Suite
5. Deployment	Release software to users	Secure configuration, patch management	Disable default admin accounts
6. Maintenance	Keep software secure after release	Regular updates, vulnerability scanning	Fix newly found security bugs

Why Secure SDLC is Important



OWASP (Open Web Application Security Project)

- **OWASP** is a **global non-profit organization** focused on improving the security of software.
- It provides:
- Free tools
- Guidelines
- Best practices for secure development



owasp

Rank	Vulnerability	Explanation	Real-Time Example
A01 – Broken Access Control	Improper enforcement of user permissions.	A normal user accesses admin panel by changing URL to `/admin`.	
A02 – Cryptographic Failures	Weak or no encryption of sensitive data.	Website stores passwords in plain text → attacker reads DB.	
A03 – Injection (SQL, NoSQL, OS, LDAP)	Unsanitized input executes code/queries.	Login form vulnerable to `' OR '1'='1` SQLi payload.	
A04 – Insecure Design	Poor architecture decisions lead to vulnerabilities.	No rate-limiting → attacker brute-forces passwords easily.	
A05 – Security Misconfiguration	Using default passwords, open ports, error messages.	Server displays full error with stack trace and DB credentials.	
A06 – Vulnerable and Outdated Components	Old libraries with known exploits.	Using outdated jQuery or PHP version vulnerable to RCE.	
A07 – Identification and Authentication Failures	Poor login/session management.	Session token never expires → attacker reuses old session.	
A08 – Software and Data Integrity Failures	Unverified updates or insecure CI/CD.	App loads untrusted JavaScript from unknown CDN.	
A09 – Security Logging and Monitoring Failures	No alerts for attacks or failures.	Brute-force attempts go unnoticed because no logging exists.	
A10 – Server-Side Request Forgery (SSRF)	App makes HTTP requests to internal systems.	Attacker inputs URL → server fetches data from internal admin panel.	

owasp

Term	Meaning
OWASP	Open Web Application Security Project
Goal	Help developers build secure software
Top 10	List of most common critical web vulnerabilities
Famous Tools	OWASP ZAP, Juice Shop, Dependency-Check
Used For	Security learning, testing, and best practices
Example	DVWA demo maps directly to OWASP Top 10 risks